0881. ○△× 24.4회.기사

NTP(Network Time Protocol) 분산 서비스 거부 취약점(CVE-2013-5211)은 NTP 서버의 특정 명령어(monlist)를 이용하여 대규모 디도스 공격을 유발할 수 있는 취약점으로 전 세계적으로 대규모 디도스 공격을 위한 위협이 되고 있다. NTP 취약점을 이용한 디도스 공격에 대응하는 방안을 4가지 서술하시오.

정답 및 해설

1) 취약한 NTP 데몬(ntpd) 버전을 업그레이드한다. NTP 데몬의 버전을 확인하여 monlist 기능이 해제된 최신 버전(4.2.7 이상)으로 업그레이드한다.
   - 버전 확인 : ntpd --version
2) 최신 버전 업그레이드가 어려운 경우 설정 변경을 통해 NTP 데몬의 monlist 기능을 해제한다.
   - 기능 해제 : ntpd 설정 파일(ntp.conf)에 'disable monitor' 추가 후 ntpd 데몬 재시작
3) 점검 대상 NTP 서버가 monlist 명령을 허용하는지 점검한다.
   - 점검 방법 : ntpdc -c monlist 〈점검 대상 NTP 서버 IP〉
4) 보안 장비(방화벽 등)를 이용하여 NTP 서버의 100byte 이상 응답을 차단 설정한다.
   - (NTP 서버) iptables 정책 설정 예 :
     iptables -A OUTPUT -p udp --sport 123 -m length --length 100: -j DROP

SECTION

5

정보보안 일반

01 정보보안 일반 단답형
02 정보보안 일반 서술형
03 정보보안 일반 실무형

SECTION 05

정보보안 일반

보안멘토

정보보호 일반 단원에서는 접근통제가 핵심 출제 영역입니다.
DAC, MAC, RBAC과 같은 다양한 접근통제 모델은 반복적으로 출제되므로, 각 모델의 특징과 차이점, 장단점 등을 중심으로 정확히 정리해 두셔야 합니다.
참고로 암호학은 실기 시험의 주요 출제 범위가 아니며, 보안 프로토콜 학습 과정에서 이미 응용되는 형태로 다루어지고 있으므로, 실기 대비 학습에서는 접근통제를 중심으로 준비하시는 것이 효과적입니다.

01. 정보보안 일반 단답형

0882. ○ △ × 16.2회.기사

다음은 정보보호의 목표에 관한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기

기밀성 : 오직 인가된 사람, 프로세스, 시스템만이 알 필요성에 근거하여 시스템에 접근해야 한다는 성질
무결성 : 정보의 내용이 불법적으로 생성 또는 변경되거나 삭제되지 않도록 보호되어야 하는 성질
(A) : 정당한 사용자가 정보시스템의 데이터 또는 자원을 필요할 때 지체없이 접근하여 사용할 수 있는 성질
(B) : 정보에 접근할 수 있는 객체의 자격이나 객체의 내용을 검증하는 데 사용되는 성질
(C) : 행위나 이벤트의 발생을 증명하여 나중에 그런 행위나 이벤트를 부인할 수 없도록 하는 것

정답 및 해설

정보보호(정보보안)의 목표는 보호해야 할 정보자산에 대해 기밀성, 무결성, 가용성을 보장하는 것이며 이를 정보보호의 3요소(CIA Triad)라고 한다. 이러한 3요소는 전통적으로 강조되는 정보보호의 목표이고 다양한 정보보호 환경을 고려하여 인증성, 책임성 등이 추가된다.

1) 기밀성(Confidentiality) : 권한 있는 자(인가된 주체, 정당한 자)만이 정보자산(객체)에 접근하여 그 내용을 알 수 있도록 보장하는 것을 말한다.
   - 정당하지 않은 자에 의해 정보가 노출되지 않도록 보장하는 것
2) 무결성(Integrity) : 권한 있는 자(인가된 주체, 정당한 자)만이 정보자산(객체)에 접근하여 그 내용을 생성하거나 변경하거나 삭제할 수 있도록 보장하는 것을 말한다.
   - 정당하지 않은 자에 의해 정보가 위변조되지 않도록 보장하는 것
3) 가용성(Availability) : 권한 있는 자(인가된 주체, 정당한 자)의 정보자산 접근 필요시 언제든지(즉시, 지체없이) 접근할 수 있도록 보장하는 것을 말한다.
   - 정당한 자의 정보자산 접근이 언제든지 가능하도록 보장하는 것
4) 인증성(Authenticity) 또는 인증(Authentication) : 인증성(인증)은 '사용자 인증'과 '메시지 인증'으로 구분해볼 수 있다.
   - 사용자 인증 : 정보자산에 접근하는 자(주체)의 신원(ID)이 주장된 실체와 일치함을 보장하는 것(즉, 사용자의 신원이 올바르다는 것을 보장하는 것)
   - 메시지 인증 : 수신한 메시지가 올바른 상대방이 보낸 메시지임을 보장하는 것
5) 책임성(Accountability) : 정보자산에 접근하는 자(주체)가 접근 결과에 대해 책임지도록 보장하는 것으로 '책임 추적성'과 '부인방지(부인봉쇄)'로 구분해 볼 수 있다.
   - 책임 추적성 : 주체를 식별해서 그 행위를 추적할 수 있도록 보장하는 것으로 이를 위해서는 주체가 유일하게 식별되어야 하고 주체의 행위를 감시하고 로깅하는 것이 필요하다.
   - 부인방지(부인봉쇄) : 주체가 한 행위를 나중에 부인하지 못하도록 보장하는 것을 말한다.

정답 (A) 가용성 (B) 인증성(인증) (C) 부인방지(부인봉쇄)

0883. ○ △ ×

다음은 정보보호 서비스에 관한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기

- (A)은/는 엘리스로부터 밥에게 전송된 메시지가 변경 없이 전송되었는지를 확인하는 보안 서비스를 말한다.
- (B)은/는 수신자 밥이 받은 메시지가 분명히 송신자 엘리스가 보낸 것인가를 확인하는 보안 서비스를 말한다.
- (C)은/는 전송 중의 메시지가 공격자에게 노출되는 것에 대응하는 보안 서비스를 말한다.
- '책임 추적성'은 정보시스템에 접근한 자를 식별해서 그 행위를 추적할 수 있도록 행위를 감시하고 로깅하는 보안 서비스를 말한다.
- '부인방지'는 통신에 참여한 주체가 송수신한 사실의 일부 또는 전부를 부인하지 못하도록 하는 보안 서비스를 말한다.

정답 및 해설

정답 (A) 무결성 (B) 인증성(인증 또는 메시지 인증) (C) 기밀성

관련지식

[Diffie-Hellman 키교환/키합의 알고리즘]

(가) 개요 15,3회,기사

① Diffie-Hellman 키교환/키합의(Diffie-Hellman Key Exchange/Key Agreement)은 1976년에 공개키 암호방식을 최초로 제안한 휘트필드 디피(Whitfield Diffie)와 마틴 헬먼(Martin Hellman)이 발명한 알고리즘이다.

② 공개키 암호방식의 개념을 이용하여 두 사용자 간에 공통의 암호화키를 안전하게 공유할 수 있는 방법을 제시하였으며, 많은 키 분배 방식에 관한 연구의 기본이 되었다.(최초의 비밀키 교환 프로토콜)

③ Diffie-Hellman 프로토콜 방법에서는 양쪽 통신주체가 KDC없이 대칭 세션키를 생성한다. 대칭키를 만들기 전에 양쪽은 두 개의 수 p와 g를 선택해야 한다. 여기서 p는 매우 큰 소수로서 300자리가 넘는 십진수(1024비트)이다.

④ "키교환"이라는 이름이 붙어 있지만 실제로는 키를 교환하는 것이 아니라 공유할 키를 계산하여 만들어 내는 것이다. 그 때문에 Diffie-Hellman 키합의(Key Agreement)라 불리기도 한다.

⑤ 유한체상의 이산대수문제를 풀기 어렵다는 것이 Diffie-Hellman 키교환의 이론적인 기반이 되고 있다.(이산대수 문제 : $G^A \bmod P$로부터 수 A를 구하는 문제)

⑥ IPsec에서는 Diffie-Hellman 키교환을 개량한 방법을 사용하고 있다.

(나) 절차 15,3회,기사

① Alice는 임의의 큰 수 x를 $0 \le x \le p-1$인에서 선택하고 $R_1 = g^x \bmod p$를 계산한다.

② Bob은 다른 임의의 큰 수 y를 $0 \le y \le p-1$인에서 선택하고 $R_2 = g^y \bmod p$를 계산한다.

③ Alice는 R_1을 Bob에게 보낸다. 여기서 Alice는 x값을 보내는 것은 아니다. 오직 R_1만 보낸다.

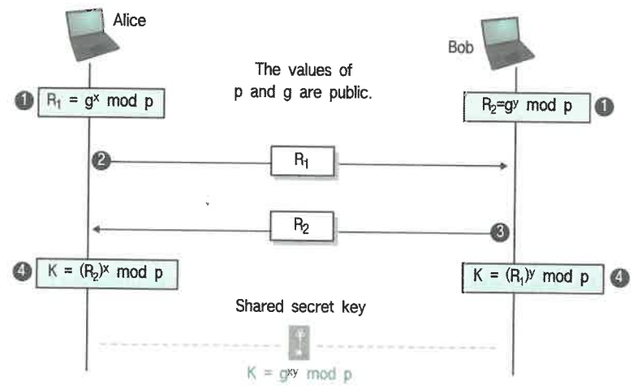
④ Bob은 R_2를 Alice에게 보낸다. 여기서도 Bob은 y값을 보내는 것이 아니고 오직 R_2만 보낸다.

⑤ Alice는 $K=(R_2)^x \bmod p$를 계산한다.

⑥ Bob은 $K=(R_1)^y \bmod p$를 계산한다.

⑦ 이렇게 구한 값 K는 아래와 같고 이것이 세션에 사용될 대칭키이다.

$$K=(g^x \bmod p)^y \bmod p = (g^y \bmod p)^x \bmod p = g^{xy} \bmod p$$



(다) Diffie-Hellman 분석

① Diffie-Hellman 개념은 매우 단순하지만 아주 훌륭한 방법이다. Alice와 Bob이 사용할 비밀키는 g, x와 y 세 부분으로 만들어진다고 생각할 수 있다.

② 첫 번째 부분은 공개되는 부분이다. 모든 사람이 이제 키의 1/3인 g값을 알고 있다는 것이다. 나머지 2/3의 1/3부분은 Alice와 Bob이 각각 채워 넣게 된다. Alice가 1/3을 채우고, Bob도 나머지 1/3을 채운다.

③ Alice는 Bob를 위해 두 번째 부분으로 x를 채우고, Bob은 Alice를 위해 두 번째 부분으로 y를 채워 넣는다. Alice가 Bob으로부터 받은 2/3가 채워진 키를 수신하면 Alice는 그것에 x를 이용하여 마지막 1/3을 채워 넣어 키를 완성한다.

④ Bob도 Alice로부터 받는 2/3가 채워진 키를 수신하면 Bob은 그것에 y를 이용하여 마지막 1/3을 채워 넣어 키를 완성한다.

(라) Diffie-Hellman의 안전성

① Diffie-Hellman 키 교환은 두 가지 공격에 약점을 보인다. 하나는 이산대수공격이고 다른 하나는 중간자 공격이다.

② 이산대수공격

- 키 교환의 안전성은 이산대수문제를 풀기 어렵다는데 기반을 두고 있다.
- Eve가 R_1과 R_2를 가로챌 수 있을 것이다. 만약 Eve가 $R_1 = g^x \bmod p$로부터 x를 구하고 $R_2 = g^y \bmod p$로부터 y를 구할 수 있다면, Eve는 대칭키 $K=g^{xy} \bmod p$를 계산할 수 있게 된다. 이렇게 되면 비밀키가 더 이상 비밀이 되지 못한다.

③ 중간자 공격(man-in-the-middle attack)

- 이 프로토콜은 또 다른 약점이 있다. Eve는 이 프로토콜을 공격하기 위해서 x와 y값을 구할 필요가 없다.
- Eve는 두 개의 키를 만들어서 Alice와 Bob을 속일 수 있다. 하나의 키는 자신과 Alice 사이에 사용할 것이고 다른 하나는 자신과 Bob 사이에 사용할 키이다.
- 키교환 프로토콜은 이런 공격에 취약한데 그 이유는 인증단계가 없기 때문이다. 이런 공격을 막기 위해서는 디지털서명과 공개키 인증서 등을 이용하면 된다.

0884. ○△× 15,3회,기사

다음은 Diffie-Hellman 키 교환 방식에 대한 설명이다. 빈칸 (A), (B), (C), (D)에 계산식을 쓰시오.

보기

1) 사용자 A와 사용자 B가 사용할 소수 p와 원시근 q를 결정한다.
2) 사용자 A는 a를 선택하고, $q^a \bmod p$를 계산하여 공개하고 사용자 B는 b를 선택하고, $q^b \bmod p$를 계산하여 공개한다.
3) 사용자 A는 사용자 B의 공개키 $q^b \bmod p$와 자신의 개인키 a를 이용하여 _(A)_을/를 계산하고 사용자 B는 사용자 A의 공개키 $q^a \bmod p$와 자신의 개인키 b를 이용하여 _(B)_을/를 계산하여 공통 비밀키로 사용한다.
4) Diffie-Hellman 키 교환 기법은 유한체의 _(C)_ 문제의 어려움에 근거하기 때문에 p로부터 a, b를 얻을 수 없으므로, _(D)_을/를 구할 수 없으므로 안전하다.

정답 및 해설

유한체상의 이산대수 문제의 어려움이 Diffie-Hellman 키 교환의 이론적인 기반이 되고 있다.
(이산대수 문제 : $G^A \bmod P$로부터 수 A를 구하는 문제)

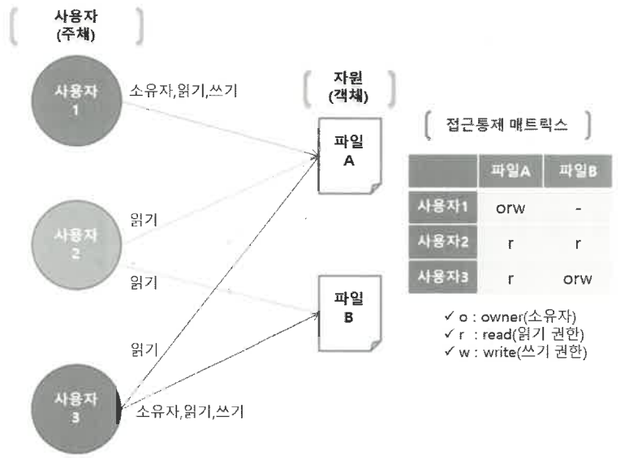
정답 (A) $q^{ba} \bmod p$ (B) $q^{ab} \bmod p$ (C) 이산대수 (D) 개인키

관련지식

[접근통제(Access Control) 정책 유형]

(1) 임의적 접근통제(DAC : Discretionary Access Control) 정책

1) 개요 14,1회,기사 19,2회,기사 22,2회,기사 13,1회,산기



	파일A	파일B
사용자1	orw	-
사용자2	r	r
사용자3	r	orw

(가) 사용자(주체)의 신원(ID : Identity) 정보와 자원에 대한 사용자의 접근권한을 기반으로 접근통제를 수행하는 정책을 말한다.
(나) 자원의 소유자(또는 관리자)가 해당 자원에 대한 다른 사용자의 접근권한을 임의로(자신의 의지대로) 지정할 수 있으므로 '임의적'이라는 용어를 사용한다.
(다) 유닉스/리눅스/윈도우 등 다양한 운영체제의 파일시스템과 데이터베이스 시스템(DBMS) 등에 적용되어 사용되고 있다.

2) 장단점

(가) 장점
① 주체(사용자)와 객체(자원) 각각에 대해 세분화된(유연한) 접근통제가 가능하다.

(나) 단점
① 중앙 집중적인 접근통제가 어렵다. 즉, 일관성 있는 접근통제 정책의 적용이 어렵다.
② 사용자의 신원 정보를 기반으로 접근통제를 수행하므로 신원 정보를 위장한 불법적인 접근이 발생하면 접근통제에 심각한 문제가 발생할 수 있다.
③ 트로이목마(trojan horse) 공격에 취약하다.

(2) 강제적 접근통제(MAC : Mandatory Access Control) 정책

1) 개요 14.1회.기사 19.2회.기사 22.2회.기사 13.1회.산기 19.1회.산기 23.1회.산기

(가) 사용자(주체)에게 부여된 '보안(비밀) 취급인가(security clearance)'와 자원(객체)에 부여된 보안 수준(security level, 보안등급)을 비교하여 접근통제를 수행하는 정책을 말한다.

- 주체와 객체에 부여된 보안 수준(보안등급)을 비교하여 접근통제 수행
- 주체와 객체에 부여된 보안 취급허가(취급인가)를 비교하여 접근통제 수행
- 주체와 객체에 부여된 보안 레이블(security label)을 비교하여 접근통제 수행

(나) 사용자가 임의로 다른 사용자에게 자원에 대한 접근권한을 설정할 수 없고 관리자(중앙 관리자, 보안관리자)에 의해서만 사용자의 보안(비밀) 취급인가와 자원의 보안 수준이 결정되어 접근통제를 수행하므로 '강제적'이라는 용어를 사용한다.

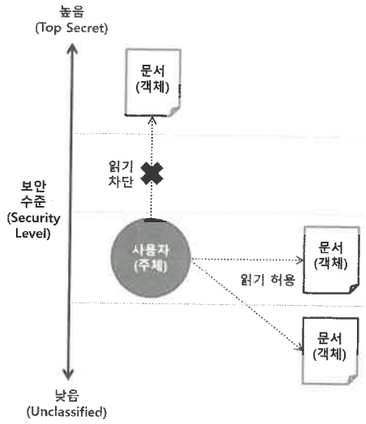
(다) 군 시스템, 보안 운영체제(Secure OS) 등 엄격한 접근통제가 요구되는 환경에 적용

2) 강제적 접근통제 기반 주요 접근통제 모델

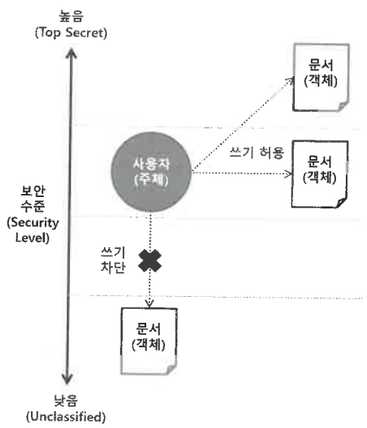
(가) BLP(Bell-LaPadula) 모델 : 벨라파둘라 모델 19.2회.기사

① 주체와 객체의 보안 수준(security level)을 비교하여 접근통제를 수행하는 모델로 최초의 수학적 접근통제 모델(수학적 검증을 거친 모델)로 알려져 있다.

② 기밀성(confidentiality)을 보장하기 위해 정보의 흐름을 통제하는 모델



<Simple Security Property(SS-Property)>
NO Read Up 속성



<Star Property(*-Property)>
NO Write Down 속성

③ No Read Up 속성(SS-Property) : 주체(사용자)보다 보안 수준(security level)이 높은 객체(예: 문서)의 정보를 읽을 수 없는 속성

- (보안 관점) 주체보다 높은 보안 수준의 객체가 가진 정보를 읽음으로써 정보의 기밀성이 훼손되는 상황을 방지할 수 있다.

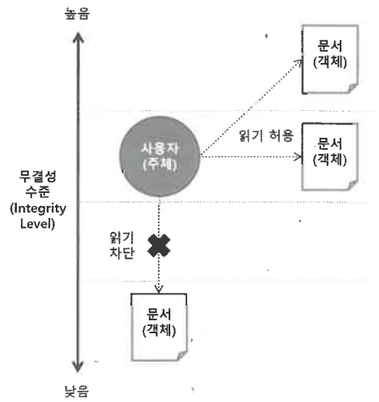
④ No Write Down 속성(*-Property) : 주체(사용자)보다 보안 수준(security level)이 낮은 객체(예: 문서)에 정보를 쓸 수 없는 속성

- (보안 관점) 주체보다 낮은 보안 수준의 객체로 정보가 유출되어 기밀성이 훼손되는 상황을 방지할 수 있다.

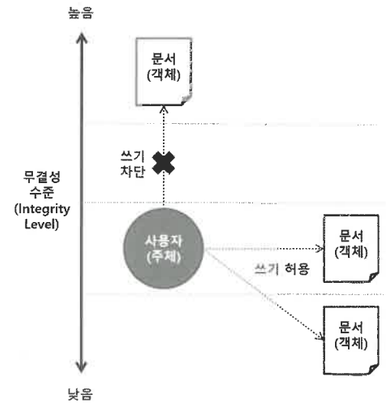
(나) Biba 모델 : 비바 모델 19.2회.기사

① 주체와 객체의 무결성 수준(integrity level)을 비교하여 접근통제를 수행하는 모델

② 무결성(integrity)을 보장하기 위해 정보의 흐름을 통제하는 모델(무결성의 3가지 목표 중 '비인가자에 의한 정보의 위변조 방지'만 해결)



<Simple Integrity Axiom(SI Axiom)>
NO Read Down 속성



<Star Integrity Axiom(*-IntegirtyProperty)>
NO Write Up 속성

③ No Read Down 속성(SI Axiom) : 주체(사용자)보다 무결성 수준(integrity level)이 낮은 객체(예: 문서)의 정보를 읽을 수 없는 속성

- (보안 관점) 주체보다 무결성 수준이 낮은 객체의 정보를 읽음으로써 주체가 알고 있는 정보의 무결성이 훼손되는 상황을 방지할 수 있다.

④ No Write Up 속성(*-Integrity Axiom) : 주체(사용자)보다 무결성 수준(integrity level)이 높은 객체(예: 문서)에 정보를 쓸 수 없는 속성

- (보안 관점) 객체보다 무결성 수준이 낮은 주체의 쓰기에 의해 객체가 가진 정보의 무결성이 훼손되는 상황을 방지할 수 있다.

(다) Clark-Wilson 모델 : 클락-윌슨 모델

① 상업적 응용에서 무결성의 3가지 목표를 모두 보장하기 위해 접근통제를 수행하는 모델

(라) Chinese Wall 모델 : 만리장성 모델

① 이해관계가 충돌하는 상업적 응용에서 기밀성과 무결성을 보장하기 위해 접근통제를 수행하는 모델

3) 장단점

(가) 장점

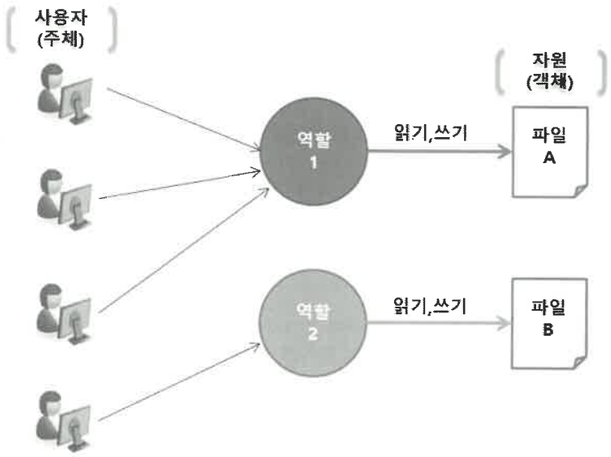
① 관리자(중앙 관리자, 보안 관리자)에 의해 일관성 있는(중앙 집중적인) 접근통제 정책을 적용할 수 있으므로 보안이 중요한 조직에 적합하다.

(나) 단점

① 관리자가 모든 접근에 대해(모든 주체와 객체에 대해) 보안 수준(Security Level)을 정의하고 접근통제 정책을 확인해야 하므로 개발 및 구현이 어렵고 성능상의 문제가 발생할 수 있다.

(3) 역할 기반 접근통제(RBAC : Role Based Access Control) 정책

1) 개요 14.1회.기사 19.2회.기사 22.2회.기사 13.1회.산기



(가) 사용자(주체)에게 부여된 역할(role)과 역할이 가지는 자원(객체)에 대한 접근권한을 기반으로 접근통제를 수행하는 정책으로 DAC과 구분하기 위해 '비임의적 접근통제(Non-DAC) 정책'이라고도 한다.

(나) 역할에 자원에 대한 접근권한을 부여하고 사용자에게 역할을 할당하는 방식이므로 개별 사용자마다 자원에 대한 접근권한을 설정할 필요가 없다. 따라서 사용자가 많고 사용자의 접근권한이 자주 변경되는 환경에서 접근통제 관리가 용이하다.

(다) 조직 내의 잦은 부서 이동 등의 이유로 조직이 동적으로 변화하는 구조에 적합한 정책이다.

2) 장단점

(가) 장점

① 관리자에 의해 일관성 있는 접근통제 정책 적용이 용이하다.

② 역할을 기반으로 자원에 대한 접근권한을 설정하므로 '직무 분리'와 '최소 권한 부여'가 용이하다.

(나) 단점

① 임의적 접근통제 정책에 비해 사용자(주체)와 자원(객체) 각각에 대한 접근권한 설정의 유연성이 떨어진다.

0885. ○△× 13.1회.산기

서버 보안시스템인 운영체제 보안시스템(SecureOS)의 평가 기준인 접근통제시스템 보호 프로파일에서 설명하고 있는 각각의 접근통제 정책을 쓰시오.

보기

(A) : 사용자가 객체에 접근할 때, 사용자와 접근허가의 직접적인 관계가 아닌 조직의 특성에 따른 역할을 매개자로 하여 사용자-역할, ·접근허가-역할의 관계를 통해 접근을 제어하는 방식

(B) : 사용자에게 부여된 접근허가 범위에 따라 객체에 대한 접근을 통제하는 방식으로 자산에 대한 침해 시도를 방지하기 위해 주체 및 객체에 등급을 부여할 경우 등급 기반 접근통제라고도 함.

(C) : 사용자나 사용자가 속한 그룹의 신원에 따라 정보에 대한 접근을 통제하는 방식으로 상용 운영체제에서 제공하는 접근통제 방식

정답 및 해설

정답 (A) 역할 기반 접근통제(RBAC) (B) 강제적 접근통제(MAC) (C) 임의적 접근통제(DAC)

0886. ○△× 14.1회.기사 22.2회.기사 24.4회.기사

다음의 빈칸 (A), (B), (C) 각각에 적절한 용어를 쓰시오.

보기

접근통제는 다양한 방법을 통해 구현할 수 있다. 그 중, 주체나 그들이 소속되어 있는 그룹들의 ID에 근거하여 객체에 대한 접근을 제한하는 방법을 _(A)_라고 한다. 또 다른 방법으로 _(B)_이/가 있는데, 이는 객체에 포함된 정보의 비밀성과 이러한 비밀 정보에 대하여 주체가 갖는 정형화된 권한에 근거하여 객체에 대한 접근을 제한하는 방법이다. 또한 보안 관리와 감사가 수월하도록 역할에 따라 접근권한을 부여하는 방법인 _(C)_이/가 있다.

정답 및 해설

정답 (A) 임의적 접근통제(DAC) (B) 강제적 접근통제(MAC) (C) 역할 기반 접근통제(RBAC)

0887. ○△× 19.1회.산기

다음 보기에서 설명하고 있는 접근통제(Access Control) 유형을 쓰시오.

보기

객체(접근 대상)에 포함된 정보의 비밀성 수준과 이러한 비밀 정보에 대하여 주체에게 부여된 접근허가범위(보안 취급인가)에 따라 객체에 대한 접근을 통제하는 방식으로 군 시스템, 보안 운영체제(Secure OS) 등 주체와 객체 간에 엄격한 접근통제가 필요한 환경에서 적용된다.

정답 및 해설

정답 강제적 접근통제(MAC)

0888. ○ △ × 19.2회.기사

다음 빈칸 (A), (B), (C) 각각에 적절한 접근통제 정책(Access Control Policy)을 쓰시오.

보기

(A) : 객체의 보안 수준(Security Level)과 주체의 보안 취급인가(Security Clearance)를 비교하여 접근을 통제하는 방식으로 관리자만이 객체의 보안 수준을 설정하고 주체에게 보안 취급인가를 허용한다.
(B) : 주체의 신원과 주체가 무엇을 할 수 있는지를 설명하는 접근규칙(Access Rule)에 근거하여 객체에 대한 접근을 제어하는 방식으로 객체의 소유자가 자신의 의지로 해당 객체에 대한 접근규칙을 결정할 수 있다.
(C) : 주체가 가지는 역할(Role)과 주어진 역할이 객체에 대한 어떤 접근이 허용되는지를 설명하는 규칙에 근거하여 접근을 통제한다.

정답 및 해설

정답 (A) 강제적 접근통제(MAC) (B) 임의적 접근통제(DAC) (C) 역할 기반 접근통제(RBAC)

0889. ○ △ × 24.2회.산기

다음 설명하는 접근제어 정책을 보기에서 고르시오.

보기

임의적 접근제어, 강제적 접근제어, 역할 기반 접근제어, 비임의적 접근제어, 직접 접근제어

램프슨(Lampson)에 의해 제안된 '접근제어 매트리스(Access Control Matrix)'를 구현하기 위해 개발된 정책으로 미국 국방성 TCSEC(Trusted Computer Security Evaluation Criteria)의 접근통제 표준 중 하나이다. 자원의 소유자가 임의로(자신의 의지로) 다른 사용자에게 해당 자원에 대한 접근권한을 설정할 수 있는 특징이 있으며 구현이 간단하지만, 바이러스, 웜, 루트킷 등에 취약한 단점이 있다.

정답 및 해설

정답 임의적 접근제어

0890. ○ △ ×

다음 보기의 빈칸( )에 적절한 강제적 접근통제 모델을 쓰시오.

보기

(A) : 기밀성을 보장하기 위해 정보의 흐름을 통제하는 모델로 군사적 목적으로 개발된 접근통제 모델이다.
(B) : 무결성을 보장하기 위해 정보의 흐름을 통제하는 모델로 무결성의 3가지 목표 중 '비인가자에 의한 정보의 위변조 방지'를 해결한 상업적 접근통제 모델이다.
(C) : 상업적 응용에서 무결성의 3가지 목표를 모두 보장하기 위해 접근통제를 수행하는 모델이다.
(D) : 이해관계가 충돌하는 상업적 응용에서 기밀성과 무결성을 보장하기 위해 접근통제를 수행하는 모델이다.

정답 및 해설

(A) BLP(벨라파둘라) 모델 (B) Biba(비바) 모델
(C) Clark-Wilson(클락-윌슨) 모델 (D) Chinese Wall(만리장성) 모델

0891. ○ △ × 19.1회.산기

다음 보기에서 설명하는 검색엔진은 무엇인지 쓰시오.

보기

웹 사이트를 검색한 결과를 보여주는 일반적인 검색엔진과 달리 인터넷에 연결된 기기(device)의 다양한 정보를 제공하는 검색엔진으로 서버, 라우터, 산업제어시스템, 스마트 TV, 스마트 냉장고, 웹캠 등 인터넷에 연결된 모든 기기가 검색의 대상이다. 인터넷에 연결된 보안 취약점을 가진 시스템, 네트워크 장비, IoT 기기 등을 찾아내 보안을 강화하기 위한 수단으로 개발된 검색엔진으로 유료 및 무료 서비스를 제공하고 있다.

정답 및 해설

쇼단(Shodan)은 라우터, 스위치, 특정 웹서버(Apache, IIS 등), CCTV 등 다양한 장비와 서비스에 대한 정보를 수집해 사용자에게 IP 정보, 국가 정보, OS 정보, 포트 정보 등의 결과를 알려주는 검색엔진(사이트, http://shodanhq.com)을 말한다. 쇼단은 각 기관(회사)에서 관리하는 장비와 서비스의 보안 취약성(취약점)을 쉽게 파악할 수 있도록 하기 위함이지만 이를 악의적인 목적으로 활용하는 문제점도 있다.

정답 쇼단(Shodan)

0892. ○△× 19.1회.산기

다음 보기에서 설명하는 용어를 쓰시오.

보기

검색엔진에 의하여 인덱싱되지 않는 인터넷 영역으로 일반적인 브라우저로는 접근할 수 없으며 암호화된 네트워크에 존재하여 특정 브라우저(예:Tor, I2P 등)를 통해서만 접근이 가능한 일련의 웹 사이트 집합체를 의미한다. 해당 사이트들은 일반 웹 사이트 도메인과 다른 형태를 보이고 있으며 철저한 익명화를 특징으로 한다. 이러한 특징 때문에 불법 유출된 개인정보, 금융정보, 악성 코드 등 많은 불법 아이템이 거래되고 있다.

정답 및 해설

인터넷(웹) 공간은 접근형태에 따라 표층웹(Surface Web), 딥웹(Deep Web), 다크웹(Dark Web)으로 구분할 수 있다. 각각의 특징은 다음과 같다.

- 표층웹(Surface Web) : 일반적으로 사용하는 웹 브라우저(크롬, IE 등)를 통해 구글, 네이버 등의 검색엔진에 접속하여 검색어를 입력한 후 접근할 수 있는 일반인에게 공개된 웹 사이트 공간을 말한다.
- 딥웹(Deep Web) : 표층웹과 달리 일반적인 검색엔진 사이트를 통해 검색되지 않는 비공개 인터넷 영역으로 개인 이메일, 회사 내부망, 유료 DB 사이트 등이 해당한다.
- 다크웹(Dark Web) : 딥웹의 일종으로 Tor, I2P 등 특수한 브라우저(소프트웨어)를 통해서만 접근이 가능한 웹으로 익명성 보장은 물론 IP 주소 추적이 불가능하도록 고안된 인터넷 영역이다. 익명성과 IP 추적을 피할 수 있다는 점 때문에 개인정보 등 불법적인 정보 거래에 악용된다.

정답 다크웹(Dark Web)

관련지식

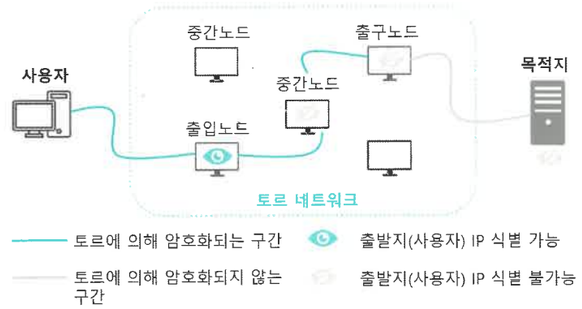
[익명 네트워크를 이용한 사이버 공격]

1) 개요

① 익명 네트워크(anonymous network)는 인터넷상에서 개인을 식별하거나 추적하는 것을 회피할 수 있도록 해주는 네트워크(익명성을 보장해 주는 네트워크)를 말한다.

② 공격자가 IP 추적이 불가능하도록 자신의 IP를 숨기거나 속이기 위해 사용하는 대표적인 기술에는 토르(Tor), 가상사설망(VPN), 프록시(Proxy) 등이 있다.

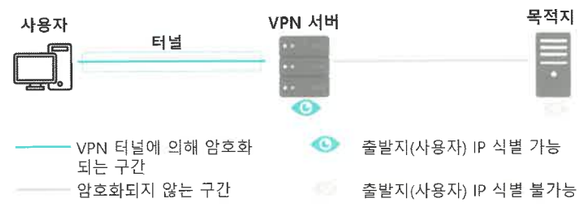
2) 토르(Tor : The Onion Router) 22.4회.산기



① 토르(Tor)는 인터넷을 익명으로 검색할 수 있도록 개발된 분산 네트워크 시스템 기반의 서비스로 토르 전용 소프트웨어가 필요하다.

② 사용자들이 직접 최종 목적지에 연결하는 대신 분산된 시스템(Onion Router, 양파 라우터)으로 구성된 릴레이 네트워크(토르 네트워크)를 통해 연결되도록 함으로써 출발지 IP를 숨길 수 있다(IP 추적을 어렵게 한다).

3) 가상사설망(VPN : Virtual Private Network) 22.4회.산기



① 가상사설망(VPN)은 공중망(인터넷)을 사설망(전용회선)처럼 이용할 수 있는 기술을 말한다.

② 사용자(VPN 클라이언트 소프트웨어 필요)가 유료 또는 무료로 제공되는 VPN 서버로 암호화된 터널(보안 채널)을 생성한 후 VPN 서버를 통해 목적지에 접속하므로 출발지 IP를 숨길 수 있다(IP 추적을 어렵게 한다).

4) 프록시(Proxy) 22,4회,산기

① 프록시(Proxy)는 클라이언트와 서버 사이에 프록시 서버(Proxy Server)를 두고 요청과 응답을 중계해 주는 방식으로 프록시 서버를 통해 목적지에 접속하므로 출발지 IP를 숨길 수 있다(IP 추적을 어렵게 한다).

② 프록시 서버(Proxy Server) : 클라이언트가 자신을 통해서 다른 네트워크 서비스에 간접적으로 접속할 수 있게 해주는 컴퓨터 시스템

0893. ○△× 22,4회,산기

공격자는 자신의 IP 주소를 속이기 위해 다음 보기의 기법을 검토하고 있다.
빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

(A) : 분산 네트워크 기반의 익명 인터넷 서비스
(B) : 인터넷과 같은 공중망을 이용하여 사설망과 같은 효과를 얻기 위한 기술
(C) : 클라이언트와 서버 사이에서 자신을 통해 다른 네트워크 서비스에 간접적으로 접속할 수 있도록 중계해 주는 방식

정답 및 해설

정답 (A) 토르(Tor) (B) 가상사설망(VPN) (C) 프록시(Proxy)

0894. ○△× 22,2회,기사

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

(A)은/는 2009년 '사토시 나카모토(Satoshi Nakamoto)'라는 가명의 개발자에 의해 개발된 가상화폐로 거래 데이터를 중앙 집중적인 방법이 아닌 분산 기록 및 저장하는 데이터베이스로 (B)을/를 이용한다. 해시 연산을 수행하여 가상화폐 블록을 생성하는 대가로 (A)을/를 획득하는 행위를 (C)이라 한다.

정답 및 해설

1. 블록체인(Block Chain) 기술의 특징을 살펴보면 다음과 같다.
   가. 블록체인은 분산 데이터 처리 기술로 네트워크에 참여한 모든 사용자가 거래 내역 등의 데이터를 분산하여 저장하는 기술이다.
   - 블록들에 정보를 저장하고 체인 형태로 연결한 구조
   - 각 블록은 개인과 개인 간의(P2P) 거래 내역 장부라고 할 수 있다.
   - 각 블록의 정보는 임의로 수정할 수 없고(위 · 변조 방지를 위한 암호화 기술 적용) 그 결과는 누구나 열람할 수 있는 특징이 있다.
   - 핵심 암호화 기술 : 해시 알고리즘(함수)

   나. 블록체인을 '공공 거래 장부' 또는 '분산 거래 장부(원장)'라고도 한다.
   다. 기존의 중앙 집중형 시스템(예: 은행 시스템의 원장 관리)의 한계를 극복한 탈중앙화 시스템을 구현할 수 있는 기술이다.
   라. 비트코인과 같은 가상화폐 등장의 기반 기술이다.
2. 가상화폐(암호화폐) 기술의 특징을 살펴보면 다음과 같다.
   가. 블록체인의 분산 원장 기술을 이용한 대표적인 디지털 화폐로 비트코인(사토시 나카모토에 의해 개발), 이더리움(비탈릭 부테린에 의해 개발) 등이 있다.
   나. 기존 전자화폐와의 차이점은 중앙 발행기관 없이 탈중앙화된 네트워크에서(예: 비트코인 네트워크) 발행한다는 점이다.
   다. 채굴(mining, 마이닝) : 참여자(개인)가 가상화폐 블록을 생성하는 과정에 참여하는 것을 채굴(마이닝)이라 한다. 합의 알고리즘, 작업 증명, 채굴에 따른 보상(암호화폐 지급) 등으로 이루어져 있다.
   - 합의 알고리즘(consensus algorithm) : 다수의 참여자가 하나의 통일된 의사결정을 하기 위해 사용하는 알고리즘
   - 작업 증명(PoW : Proof of Work) : 블록을 생성하기 위한 해시 연산 작업을 특정 난이도에 수행하고 이를 증명하는 것

   라. 채굴을 통해 생성한 블록 단위로 거래(transaction) 내역이 기록된다.

정답 (A) 비트코인(bitcoin) (B) 블록체인(block chain) (C) 채굴(마이닝, mining)

02. 정보보안 일반 서술형

관련지식

[전자서명/디지털서명(digital signature)]

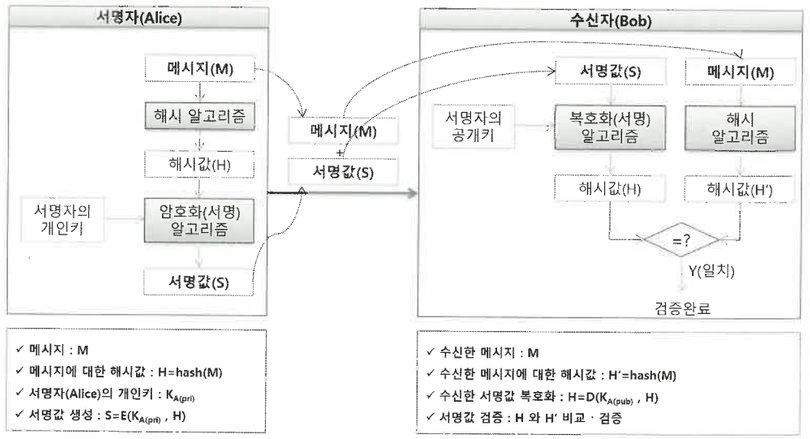
(1) 개요 13.2회.기사 15.2회.산기

(가) 현실 세계의 사인, 서명날인 등을 디지털 세계로 구현한 기술을 전자서명/디지털서명이라 한다. 사인, 서명날인이 현실 세계에서 특정 개인의 신원(신분)을 확인할 수 있는 도구라면 디지털 세계에서는 공개키 암호방식의 개인키(private key)가 그러한 역할을 한다.

(나) 서명자만이 자신의 개인키를 이용하여 생성할 수 있는 메시지에 대한 고유한 서명을 이용하여 '메시지에 대한 무결성(Integrity)과 인증(Authentication), 부인방지(Non-repudiation)'를 보장해 주는 암호학적 도구이다.

- 메시지 무결성 : 서명자가 작성한 메시지가 위변조되지 않았음을 보장해 준다.
- 메시지 인증 : 메시지가 올바른 상대방(서명자)이 보낸 메시지임을 보장해 준다.
- 부인방지 : 메시지를 보낸 상대방(서명자)이 나중에 자신이 보낸 메시지가 아니라고 부인하지 못하도록 보장해 준다.

(2) 전자서명 생성 및 검증 방식



(가) 메시지 또는 메시지의 해시값을 서명자의 개인키로 서명하여(암호화하여) 서명값(암호문)을 생성한 후 메시지와 함께 전송하면, 수신자는 서명자의 공개키로 서명값(암호문)을 복호화한 후 수신한 메시지 또는 메시지의 해시값과 비교하여 검증한다.

- 메시지 복원형 : 메시지 전체를 서명하여 검증하는 방식
- 메시지 부가형 : 메시지의 해시값을 서명하여 검증하는 방식

(3) 전자서명 요구 조건(기능)

(가) 위조 불가(unforgeable) : 서명자 외에는 서명값을 생성할 수 없어야 한다.
- 정당한 서명자만이 서명값을 생성할 수 있어야 한다.

(나) 변경 불가(unalterable) : 서명한 메시지의 내용을 변경할 수 없어야 한다.

(다) 서명자 인증(user authentication) : 서명값을 통해서 서명자를 확인할 수 있어야 한다.
- 서명자의 공개키로 서명값을 검증함으로써 서명자 인증 조건을 만족시킨다.

(라) 부인방지(non-repudiation) : 서명자가 나중에 서명한 사실을 부인할 수 없어야 한다.
- 서명자만이 가지고 있는 개인키로 서명하기 때문에 부인방지 조건을 만족시킨다.

(마) 재사용 불가(not reusable) : 생성한 서명값을 다른 메시지의 서명값으로 사용할 수 없어야 한다.

0895. ○△× 15.2회.산기

전자서명을 통하여 제공할 수 있는 가장 대표적인 보안 서비스 세 가지를 기술하고 각각에 대해 설명하시오.

정답 및 해설

- 메시지 무결성(Integrity) : 서명자가 작성한 메시지가 위변조되지 않았음을 보장해 준다.
- 메시지 인증(Authentication) : 메시지가 올바른 상대방이(서명자가) 보낸 것임을 보장해 준다.
- 부인방지(Non-repudiation) : 메시지를 보낸 상대방(서명자)이 나중에 자신이 보낸 메시지가 아니라고 부인하지 못하도록 보장해 준다.

0896. ○△× 13.2회.기사

송신자로부터 전달된 전자문서와 PKI(Public Key Infrastructure) 기반 전자서명 정보를 수신자가 검증에 성공한 경우 수신자가 확인할 수 있는 사실을 세 가지 이상 기술하고 각각에 대해 설명하시오.

정답 및 해설

- 메시지 무결성(Integrity) : 서명자가 작성한 메시지가 위변조되지 않았음을 보장해 준다.
- 메시지 인증(Authentication) : 메시지가 올바른 상대방이(서명자가) 보낸 것임을 보장해 준다.
- 부인방지(Non-repudiation) : 메시지를 보낸 상대방(서명자)이 나중에 자신이 보낸 메시지가 아니라고 부인하지 못하도록 보장해 준다.

0897. ○△×

전자서명/디지털서명(Digital Signature)의 요구 조건 5가지를 서술하시오.

정답 및 해설

전자서명/디지털서명의 요구 조건은 다음과 같다.

- 위조 불가(unforgeable) : 서명자 외에는 서명값을 생성할 수 없어야 한다.
- 변경 불가(unalterable) : 서명한 메시지의 내용을 변경할 수 없어야 한다.
- 서명자 인증(user authentication) : 서명값을 통해서 서명자를 확인할 수 있어야 한다.
- 부인방지(non-repudiation) : 서명자가 나중에 서명한 사실을 부인할 수 없어야 한다.
- 재사용 불가(not reusable) : 생성한 서명값을 다른 메시지의 서명값으로 사용할 수 없어야 한다.

0898. ○△× 16.2회.산기

전자 금융 거래 시 사용하는 현재의 OTP는 보안을 위해 자동응답(ARS), 문자 메시지(SMS) 등 추가 인증이 필요하다. 하지만 '스마트 OTP'는 추가 인증이 필요 없는 장점이 있다. 스마트 OTP를 통한 인증 방식의 동작 원리를 서술하시오.
(단, 스마트 OTP의 발급 은행과 사용자가 동일한 은행을 이용한다는 조건으로 서술)

정답 및 해설

- 스마트 OTP는 기존의 OTP 대신 스마트폰과 IC 카드를 이용해 인증한다. 이때 ARS나 SMS를 통한 추가적인 인증은 필요하지 않다.
- 고객은 거래 중인 은행에서 비밀번호 생성에 필요한 정보가 담긴 IC 카드를 발급받는다.
- 금융 거래 시 기존의 보안카드나 OTP를 통해 생성된 숫자를 입력하는 대신, 거래 은행에서 발급받은 IC 카드를 스마트폰에 접촉하면 자동으로 숫자가 생성되어 입력된다. 이때 스마트폰은 전용 앱이 설치되어야 하고, NFC(근거리 무선통신)가 지원되어야 한다.

0899. ○△× 23.1회.산기

다음 보기는 접근통제(Access Control) 유형에 대한 설명이다. 각각의 질문에 답하시오.

보기

- 주체와 객체에 부여된 보안 수준(Security Level)을 비교하여 접근통제를 수행
- 보안 관리자가 취급 인가를 허용한 개체만이 접근할 수 있도록 강제적 통제 수행
- 다중 수준 보안(Multilevel Security) 정책에 기반한 접근통제 수행

1) 접근통제 유형의 명칭과 장단점을 쓰시오.

2) (1)의 접근통제 유형을 구현한 접근통제 보안모델 3가지를 쓰시오.

정답 및 해설

1) 접근통제 유형의 명칭과 장단점
   - (명칭) 강제적 접근통제(MAC)
   - (장점) 관리자(중앙 관리자, 보안 관리자)에 의해 일관성 있는(중앙 집중적인) 접근통제 정책을 적용할 수 있으므로 보안이 중요한 조직에 적합하다.
   - (단점) 관리자가 모든 접근에 대해(모든 주체와 객체에 대해) 보안 수준(Security Level)을 정의하고 접근통제 정책을 확인해야 하므로 개발 및 구현이 어렵고 성능상의 문제가 발생할 수 있다.
2) BLP(Bell-LaPadula) 모델, Biba 모델, Clark-Wilson 모델, Chinese Wall 모델 중 3가지

0900. ○△× 19.2회.기사

다음의 강제적 접근통제(MAC:Mandatory Access Control) 모델에 대한 각각의 질문에 답하시오.

1) 정보의 흐름 통제를 통해 보호 대상에 대한 기밀성을 보장하는 강제적 접근통제 모델은 무엇인가?

2) (1)의 모델에서 'No Read Up 속성'에 대해 설명하시오.

3) (1)의 모델에서 'No-Write-Down 속성'을 설명하고 보안성 측면에서 그 이유를 설명하시오.

4) 비바(Biba) 모델에서 쓰기(Write) 속성을 설명하시오.

정답 및 해설

1) BLP(Bell-LaPadula) 모델 : 벨라파둘라 모델
2) 주체(사용자)보다 보안 수준(Security Level)이 높은 객체(예: 문서 등)의 정보를 읽을 수 없는 속성을 말한다.
3) 주체(사용자)보다 보안 수준(Security Level)이 낮은 객체(예: 문서 등)에 정보를 쓸 수 없는 속성을 말한다. 이를 통해 주체보다 낮은 보안 수준의 객체로 정보가 유출되어 기밀성이 훼손되는 상황을 방지할 수 있다.
4) 비바(Biba) 모델에서는 No-Write-Up 속성을 사용하는데 이는 주체(사용자)보다 무결성 수준(Integrity Level)이 높은 객체(예: 문서 등)에 정보를 쓸 수 없는 속성을 말한다. 이를 통해 객체보다 무결성 수준이 낮은 주체의 쓰기에 의해 객체가 가진 정보의 무결성이 훼손되는 상황을 방지할 수 있다.

0901. ○△× 24.1회.산기

보안 운영체제의 강제적 접근제어(MAC) 정책의 하나인 MLS(Multi Level Security, 다단계 보안)는 객체가 포함하고 있는 정보의 비밀성과 주체가 갖는 권한을 기반으로 강제적 접근제어를 하는 방식이다. MLS에서 정보의 흐름을 제어하기 위해 'No Read Up 규칙'과 'No Write Down 규칙'을 적용하는데 각 규칙의 개념과 어떠한 보안 위협에 대응할 수 있는지 서술하시오.

정답 및 해설

1) No Read Up 규칙
- (개념) 주체보다 보안 수준(비밀성)이 높은 객체의 정보를 읽을 수 없는 규칙
- (보안 위협) 주체보다 높은 보안 수준의 객체가 가진 정보를 읽음으로써 정보의 기밀성이 훼손되는 상황을 방지할 수 있다.
  (또는 권한 없는 자에 의해 기밀(비밀) 정보가 탈취되어 기밀성이 훼손되는 상황을 방지할 수 있다)

2) No Write Down 규칙
- (개념) 주체보다 보안 수준(비밀성)이 낮은 객체에 정보를 쓸 수 없는 규칙
- (보안 위협) 주체보다 낮은 보안 수준의 객체로 정보가 유출되어 기밀성이 훼손되는 상황을 방지할 수 있다.
  (또는 주체가 알고 있는 기밀(비밀) 정보가 노출되어 기밀성이 훼손되는 상황을 방지할 수 있다)

03. 정보보안 일반 실무형

관련지식

[공개키 기반 구조(PKI : Public Key Infrastructure)]

(1) 개요

(가) 공개키 기반 구조(PKI)는 공개키(비대칭키) 암호화 방식에서 사용하는 공개키 인증을 위한 기반 환경/구조를 말한다.

(나) 공개키가 누구의 공개키인지 인증하는 데 필요한 기반 환경/구조를 말하여 공개키에 대한 인증서 생성, 관리, 저장, 배포 및 폐지 등에 필요한 구성 요소들의 집합이다.

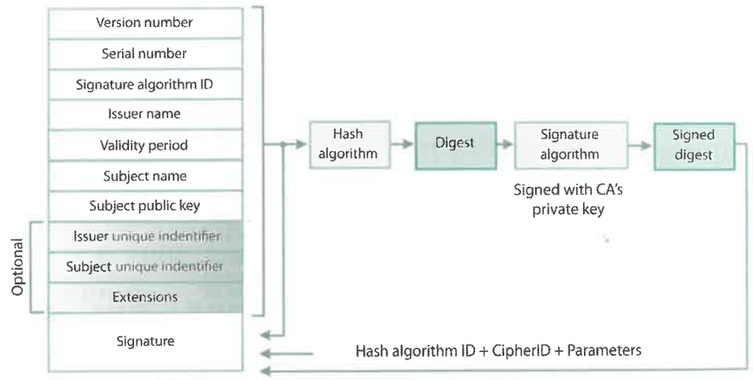
(다) PKI 구성 요소로 인증기관(CA : Certificate Authority), 등록기관(RA : Registration Authority), 인증서(Certificate), 저장소/보관소(Repository) 등이 있다.

(2) PKI 구성 요소

1) 인증서(Certificate) : 공개키 인증서

(가) 공개키와 함께 공개키 인증에 필요한 정보(주체, 발급자 등)를 인증기관(CA)이 서명한 전자문서로 인증기관이 발급한다.
- 인증서 표준 형식 : X.509 표준(현재 X.509v3(버전 3))을 가장 많이 사용)
- X.509 구문 표기 형식 : ASN.1(Abstract Syntax Notation)

(나) X.509 인증서 항목 : 기본 영역 항목과 버전에 따른 확장 영역 항목으로 구성되어 있다. 기본 영역의 주요 항목을 살펴보면 다음과 같다.



① 버전(Version number) : 인증서 버전 정보, V3(X.509v3)

② 일련번호(Serial number) : 인증기관별로 각 인증서를 식별하기 위한 일련번호

③ 서명 알고리즘 식별자(Signature algorithm ID) : 인증기관이 인증서 내용에 서명할 때 사용한 알고리즘 ID

- (예) SHA256RSA : 인증서의 내용을 SHA256(서명 해시 알고리즘)으로 해시한 후 해시값을 인증기관의 RSA 개인키로 디지털 서명한다는 의미이다.

④ 발급자(Issuer name) : 인증서를 발급한 인증기관의 DN(Distinguished Name) 정보

- DN(Distinguished Name) : X.500 표준(디렉터리 서비스)에서 정의하는 자원 식별을 위한 명명 규칙
- (예시) C=US, O=DigiCert inc, OU=www.digicert.com, CN=DigiCert SHA2 Extended Validation Server CA : C(Country, 국가), O(Organization, 기관명), OU(Organization Unit, 부서명), CN(Common Name, 이름)

⑤ 유효기간(Validity period) : 인증서의 유효기간으로 시작일(From)과 종료일(To)을 지정한다.

⑥ 주체(Subject name) : 인증서 소유자에 대한 DN(Distinguished Name) 정보

- (예시) C=KR, S=Seoul, L=Dongjag-gu, O=zianedu, CN=www.algisa.com

⑦ 주체 공개키(Subject public key) : 인증기관이 인증한 주체의 공개키

⑧ 서명(Signature) : 인증기관이 서명한 서명값

2) 인증기관(CA : Certificate Authority) 15.1회.산기

(가) 인증서 정책 수립 및 인증서의 발급/재발급/갱신/효력 정지 및 회복/폐지 등의 업무를 수행하는 기관을 말한다.

(나) 인증기관은 최상위에 '루트(Root) CA'가 위치하고 그 하위에 CA가 계층적으로 위치하는 트리 형태로 이루어져 있다.

- 상위 인증기관이 하위 인증기관의 인증서를 발행하며 하위 인증기관은 상위 인증기관의 인증정책에 영향을 받는다.

(다) 인증서 폐지 목록(CRL)과 OCSP 서비스를 제공한다. 15.1회.산기

① 인증서 폐지 목록(CRL : Certificate Revocation List) : 인증서 유효기간 만료 전 폐지나 효력 정지된 인증서 목록으로 사용자가 인증서의 유효성을 확인할 수 있도록 해당 인증기관이 배포한다.

- CRL은 실시간 정보가 반영된 목록이 아닌 일정 주기로 배포되는 목록으로 실시간 인증서 상태 확인을 위해서는 OCSP 서비스를 이용한다.
- 인증서 확장 영역의 'CRL 배포 지점(distribution point)' 항목에 인증기관의 CRL 배포 URL이 설정되어 있다.

- 인증서 폐지 사유 : 인증서 유효기간 만료 전 폐지하는 사유의 예
  - 주체의 개인키(인증서에 있는 공개키와 쌍인 개인키)가 유출되거나 손상되었을 때 주체의 요청 또는 인증기관의 직권으로 폐지한다.
  - 인증기관(CA)의 개인키(인증서 서명에 사용한 개인키)가 유출되거나 손상되었을 때 인증기관은 서명한 인증서를 모두 폐지한다.
  - 인증기관(CA)이 주체를 더 이상 인증하지 않는 경우 인증서를 폐지한다.

② OCSP(Online Certificate Status Protocol) 서비스 : 사용자가 온라인으로 실시간 인증서 상태정보(정상/효력 정지/폐지 등)를 확인할 수 있는 인증기관이 제공하는 서비스

- 인증서 확장 영역의 '기관 정보 액세스(AIA : Authority Information Access)' 항목에 인증기관에서 제공하는 OCSP 서버의 URL이 설정되어 있다.

3) 등록기관(RA : Registration Authority) 15.1회.산기

(가) 인증기관(CA)을 대신해서 인증서 발급/재발급/갱신 등의 서비스 요청자에 대한 신원확인 및 인증기관에 요청 등록 대행 업무를 수행하는 기관을 말한다. 주요 역할을 살펴보면 다음과 같다.

- 요청자 신원확인
- 인증서 발급 등 등록 대행 업무 및 기록 보관

(나) 요청자와 인증기관(CA) 사이에 인터페이스 역할을 하며 대표적인 등록기관으로 신원확인이 가능한 금융기관(은행, 증권사 등)이 있다.

4) 저장소/보관소(Repository)

(가) 인증기관에서 사용자 인증서(Certificate), 인증서 폐지 목록(CRL) 등을 저장하는 일종의 데이터베이스를 말한다.

(나) 정보 저장을 위해 DAP/LDAP(디렉터리 서비스)을 주로 사용한다.

0902. ○△× 15.1회.산기

PKI(Public Key Infrastructure, 공개키 기반 구조)란 공개키 알고리즘을 통한 암호화 및 전자서명을 제공하는 복합적인 보안시스템 환경이다. 즉, 암호화와 복호화를 위한 개인키와 공개키로 구성된 구조를 이용하여 송수신 데이터를 암·복호화하고 디지털 인증서를 통해 사용자를 인증하는 시스템이다. 이때 PKI를 구성하는 객체인 CA, RA, CRL이 무엇인지 간단히 설명하시오.

정답 및 해설

1) CA(Certificate Authority, 인증기관) : 인증서 정책 수립 및 인증서의 발급/재발급/갱신/효력 정지 및 회복/폐지 등의 업무를 수행하는 기관을 말한다.
2) RA(Registration Authority, 등록기관) : 인증기관(CA)을 대신해서 인증서 발급/재발급/갱신 등의 서비스 요청자에 대한 신원확인 및 인증기관에 요청 등록 대행 업무를 수행하는 기관을 말한다.
3) CRL(Certificate Revocation List, 인증서 폐지 목록) : 인증서 유효기간 만료 전 폐지나 효력 정지된 인증서 목록으로 사용자가 인증서의 유효성을 확인할 수 있도록 인증기관이 배포한다.

0903. ○△×

공개키 기반 구조(PKI : Public Key Infrastructure)와 관련하여 다음 각각의 질문에 답하시오.

1) 인증서 폐지 목록(CRL)에 관해 설명하시오.

2) OCSP(Online Certificate Status Protocol)에 관해 설명하시오.

3) 인증서 폐지 사유에 대해 2가지 이상 서술하시오.

정답 및 해설

1) 인증서 폐지 목록(CRL)은 인증서 유효기간 만료 전 폐지나 효력 정지된 인증서 목록으로 사용자가 인증서의 유효성을 확인할 수 있도록 인증기관이 배포한다.
2) OCSP 서비스는 사용자가 온라인으로 실시간 인증서 상태정보(정상/효력 정지/폐지 등)를 확인할 수 있는 인증기관이 제공하는 서비스를 말한다.
3) 인증서 폐지 사유의 예는 다음과 같다.
   - 주체의 개인키(인증서에 있는 공개키와 쌍인 개인키)가 유출되거나 손상되었을 때 주체의 요청 또는 인증기관의 직권으로 폐지한다.
   - 인증기관(CA)의 개인키(인증서 서명에 사용한 개인키)가 유출되거나 손상되었을 때 인증기관은 서명한 인증서를 모두 폐지한다.
   - 인증기관(CA)이 주체를 더 이상 인증하지 않는 경우 인증서를 폐지한다.

0904. ○△×

공개키 기반 구조(PKI : Public Key Infrastructure)를 구성하는 공개키 인증서(X.509v3)는 기본 영역과 확장 영역으로 구분되는 다양한 항목을 가지고 있다. 다음에 나열한 각 항목의 의미를 간단히 쓰시오.

1) 일련번호(Serial Number), 2) 서명 알고리즘 식별자(Signature algorithm ID)

3) 주체(Subject name), 4) 발급자(Issuer), 5) 서명(Signature)

정답 및 해설

1) 일련번호(Serial Number) : 인증기관별로 각 인증서를 식별하기 위한 일련번호
2) 서명 알고리즘 식별자(Signature algorithm ID) : 인증기관이 인증서 내용을 서명할 때 사용한 알고리즘 ID
3) 주체(Subject name) : 인증서 소유자에 대한 DN(Distinguished Name) 정보
4) 발급자(Issuer) : 인증서를 발급한 인증기관의 DN(Distinguished Name) 정보
5) 서명(Signature) : 인증기관이 서명한 서명값

SECTION

6

정보보안관리/법규

01 정보보안관리/법규 단답형
02 정보보안관리/법규 서술형
03 정보보안관리/법규 실무형